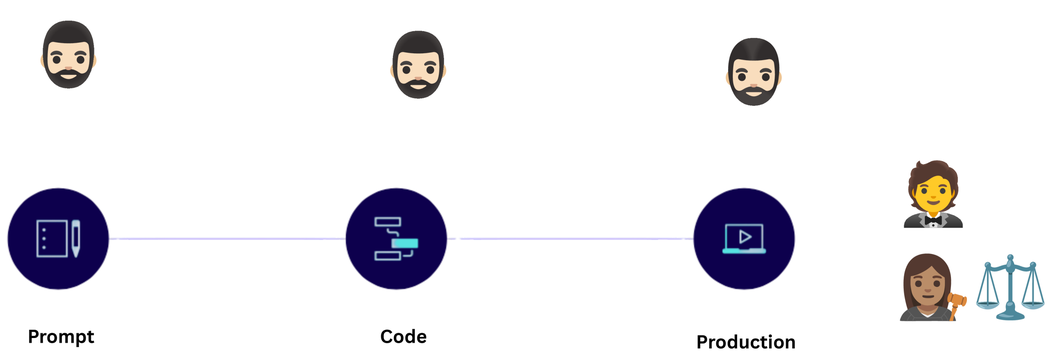
🌎 ISO 42001 (AI Management system)

🇪🇺 EU AI Act (2024 - 2028)

🇺🇸 Great American AI Act (Draft)

🇺🇸 California AI Transparency Act

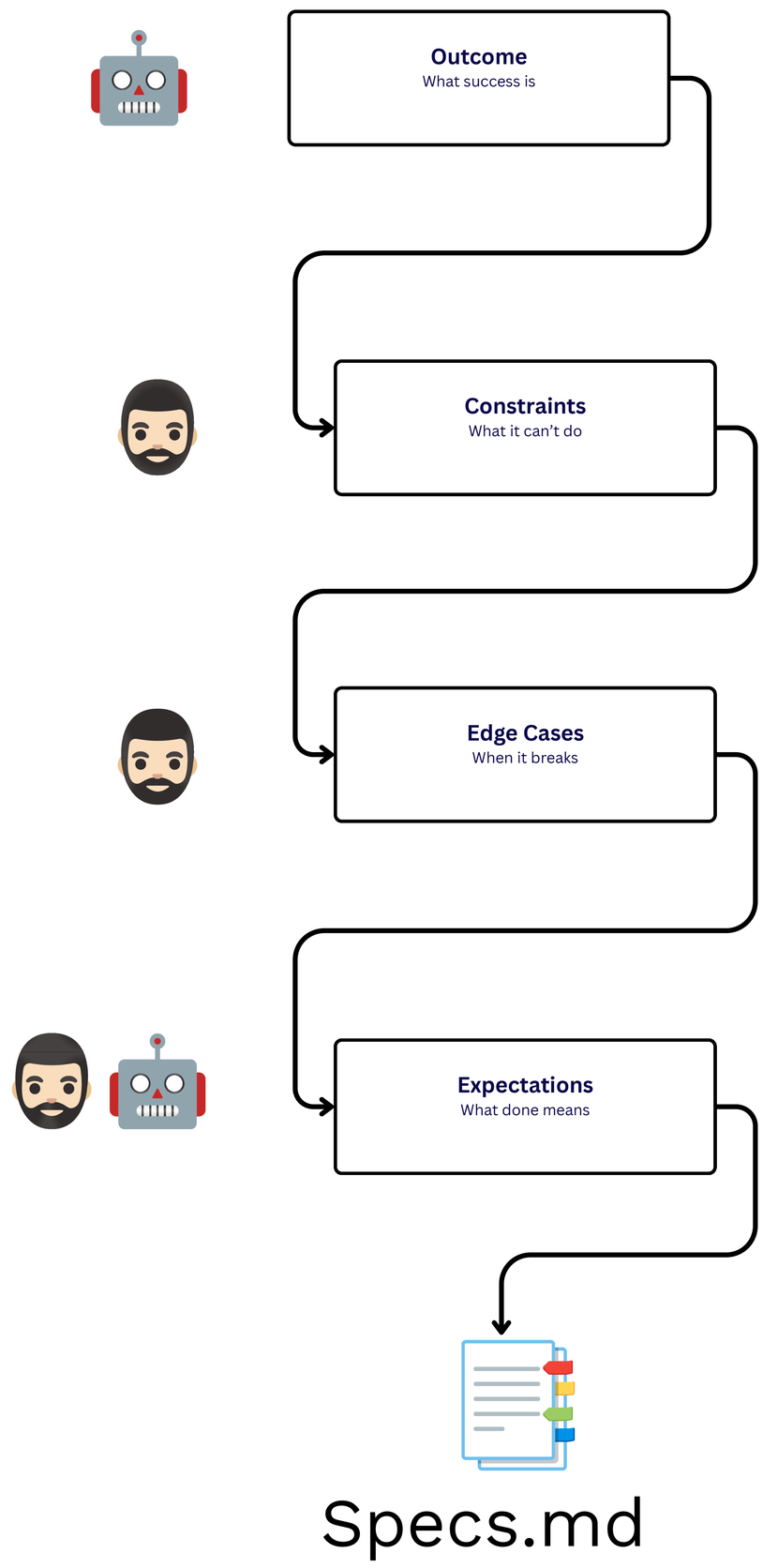
🌎 Regulated industries (Fintech, Healthcare, Insurance, Government)



Hitl = Human in the loop

Hotl = Human on the loop

Hootl = Human out of the loop


Outcome
What success is
Constraints
What it can’t do
Edge Cases
When it breaks
Expectations
What done means

Specs.md

Is correct ?
Bugs and Edge Cases

Spect

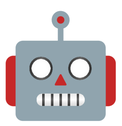
Is it maintainable ?
Readability and Design

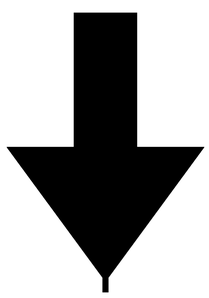
Compilant Regulation

Is it secure?
Thread Model

Code Gate









Prompt



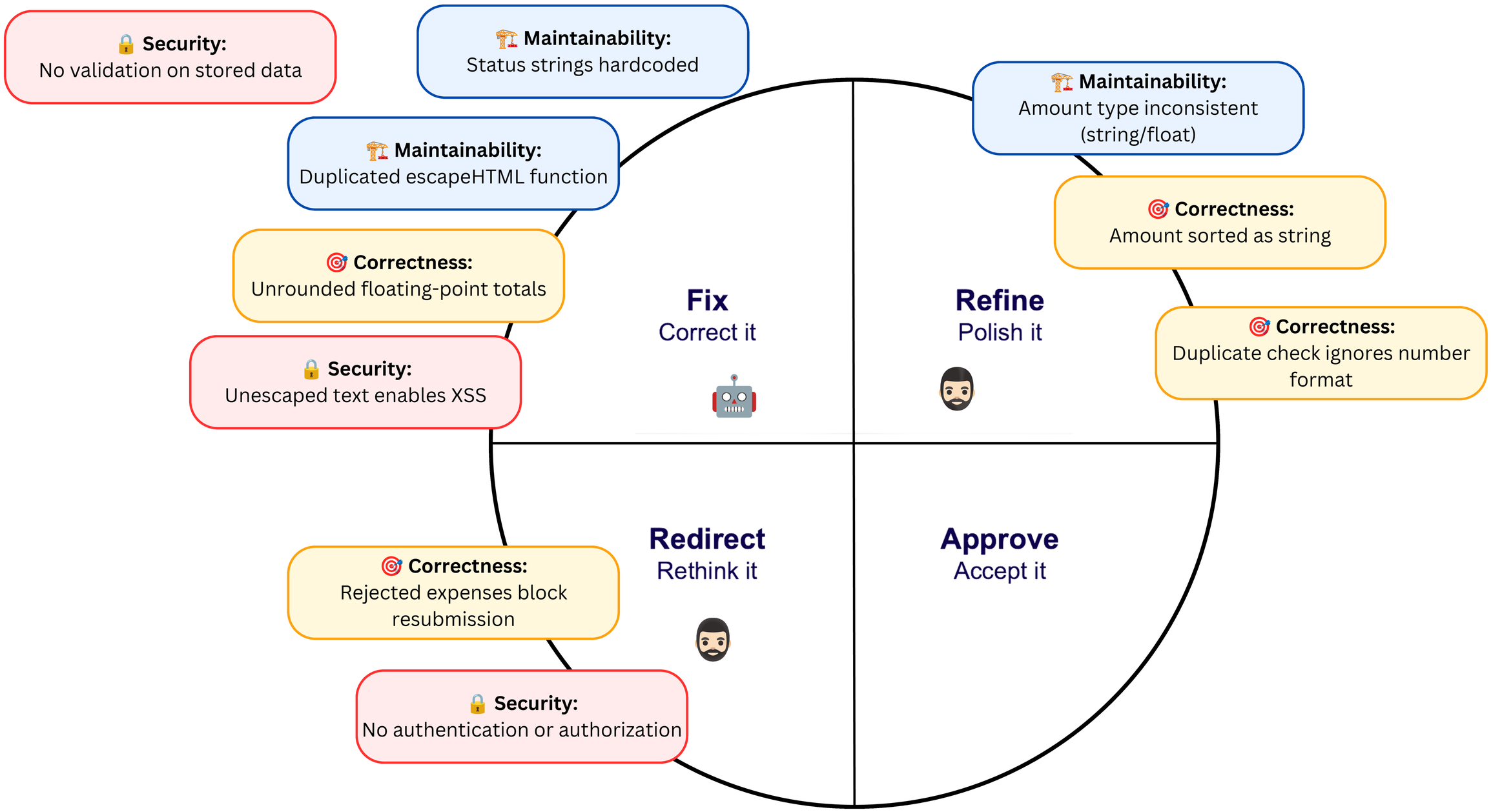
Code

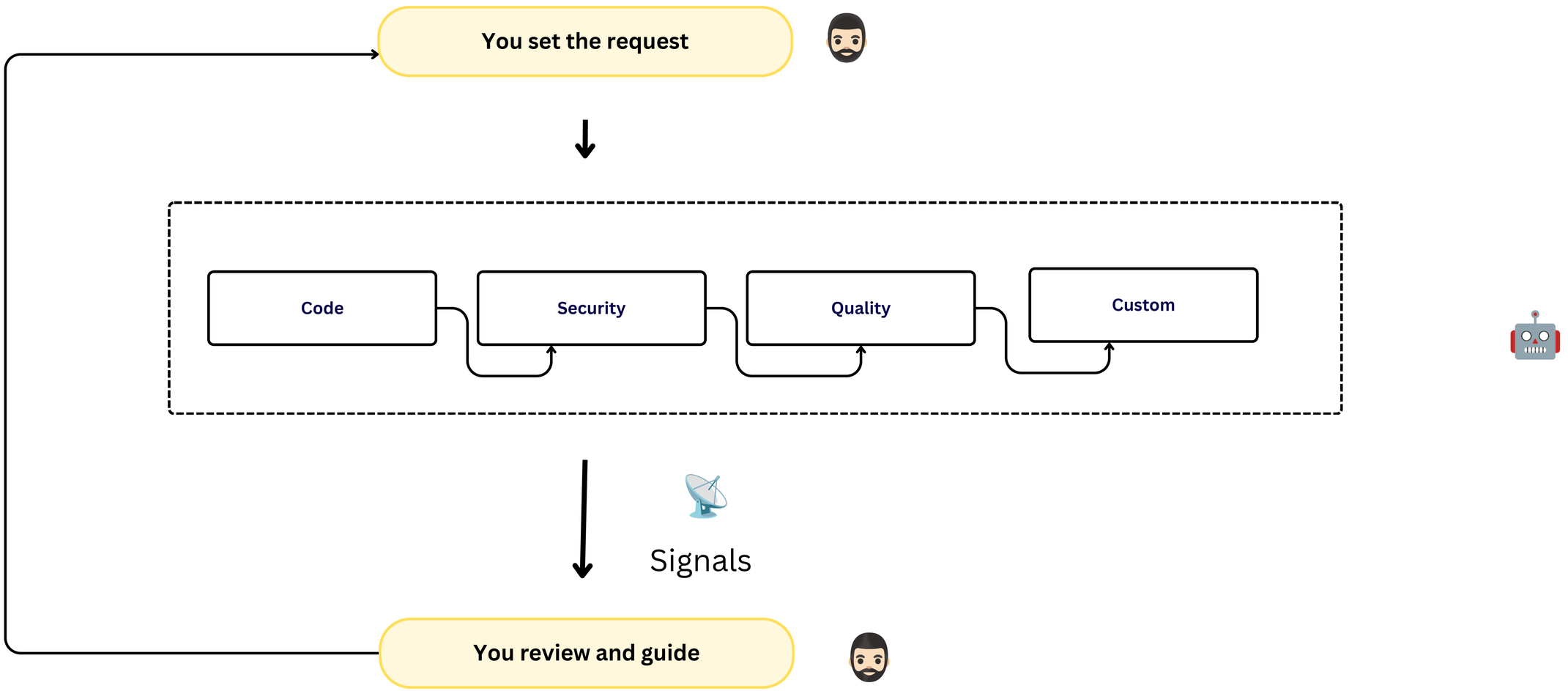


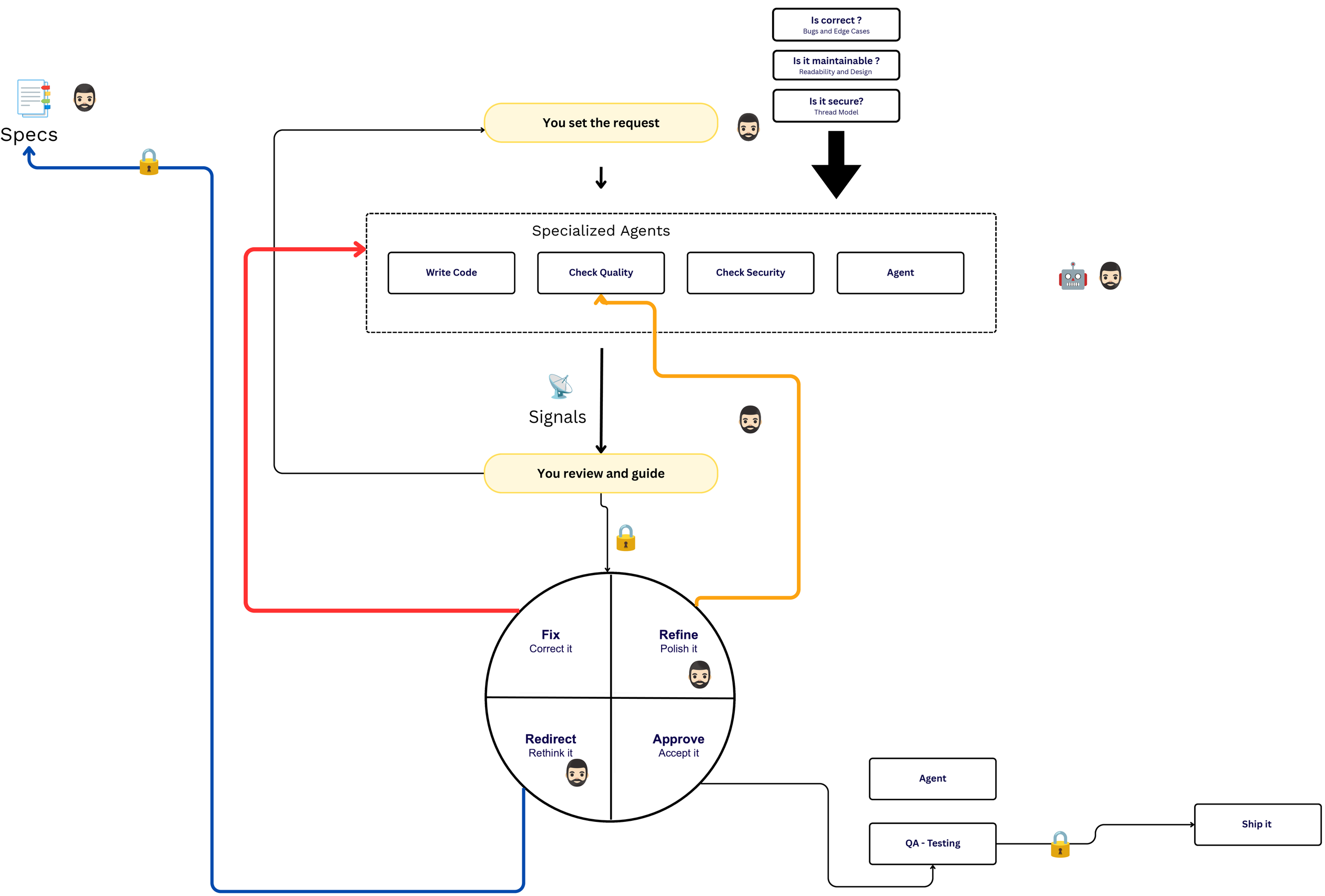
Production

Tests

Tests


🔒 Security:
No validation on stored data
🏗️ Maintainability:
Status strings hardcoded
🏗️ Maintainability:
Duplicated escapeHTML function
🎯 Correctness:
Unrounded floating-point totals
🔒 Security:
Unescaped text enables XSS
🏗️ Maintainability:
Amount type inconsistent (string/float)
🎯 Correctness:
Amount sorted as string
🎯 Correctness:
Duplicate check ignores number format
Fix
Correct it
Refine
Polish it
🎯 Correctness:
Rejected expenses block resubmission
🔒 Security:
No authentication or authorization
Redirect
Rethink it
Approve
Accept it


You set the request
Code
Security
Quality
Custom
Signals
You review and guide



“Human in the loop....
and green tea in the kettle to code wisely”